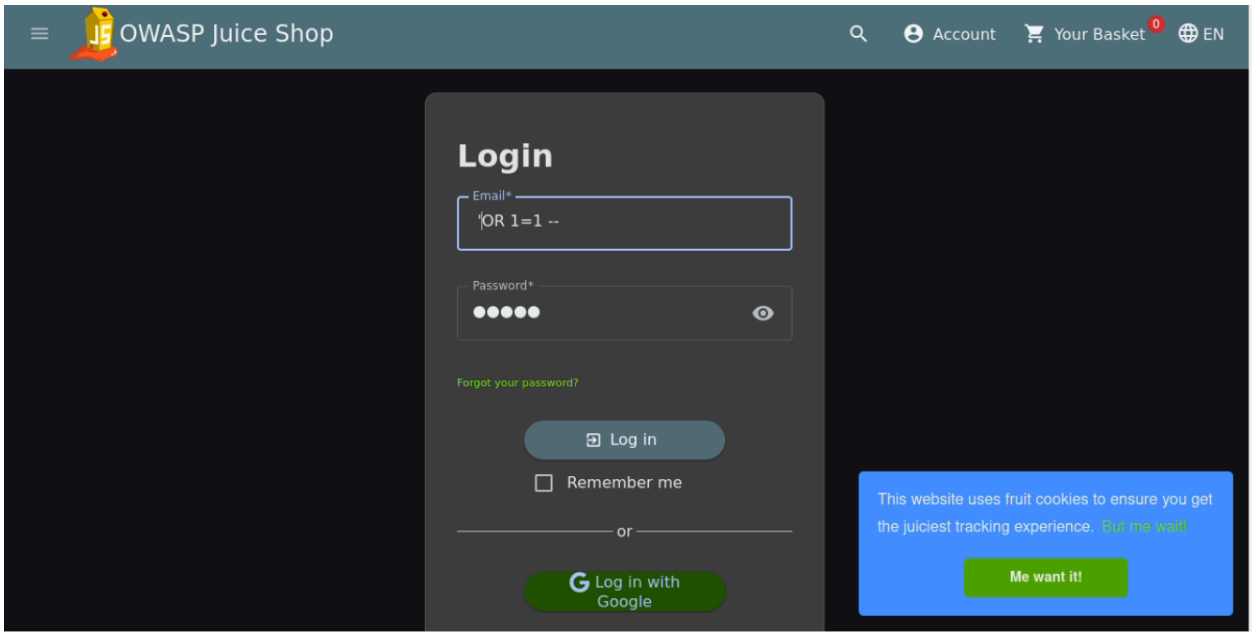
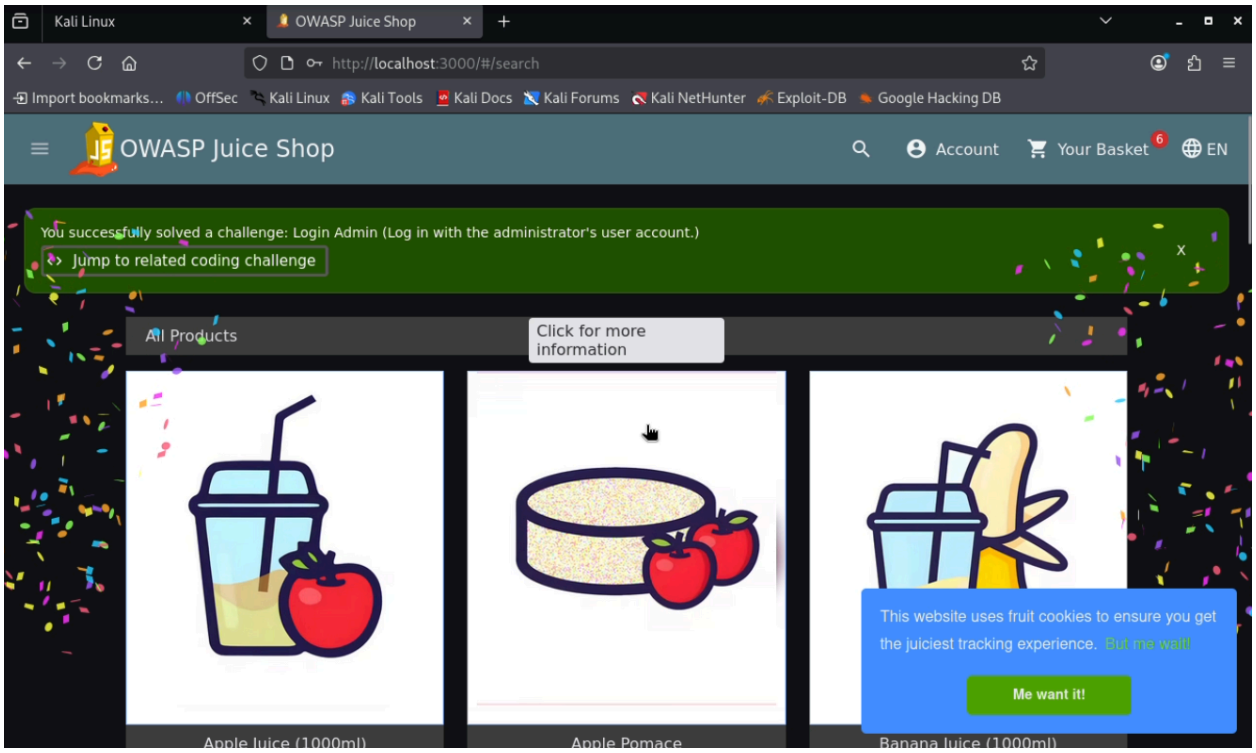
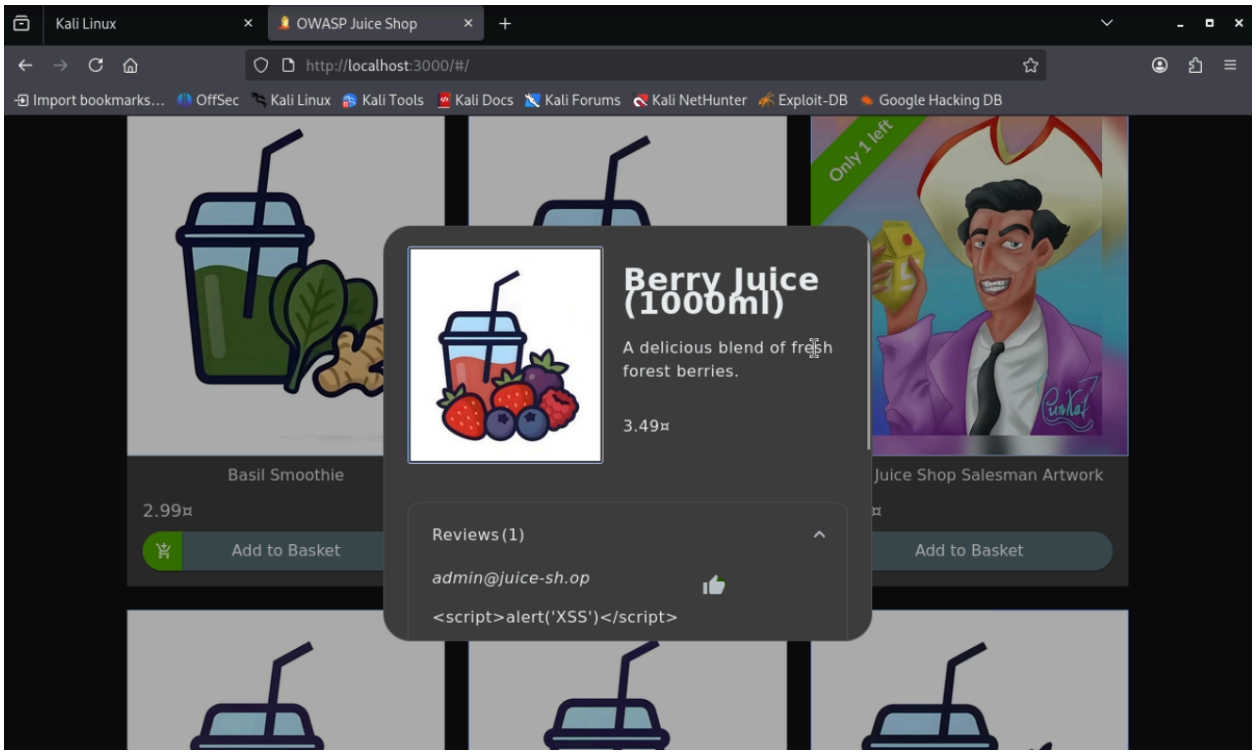
"Task One: SQL Injection - Login Proof"

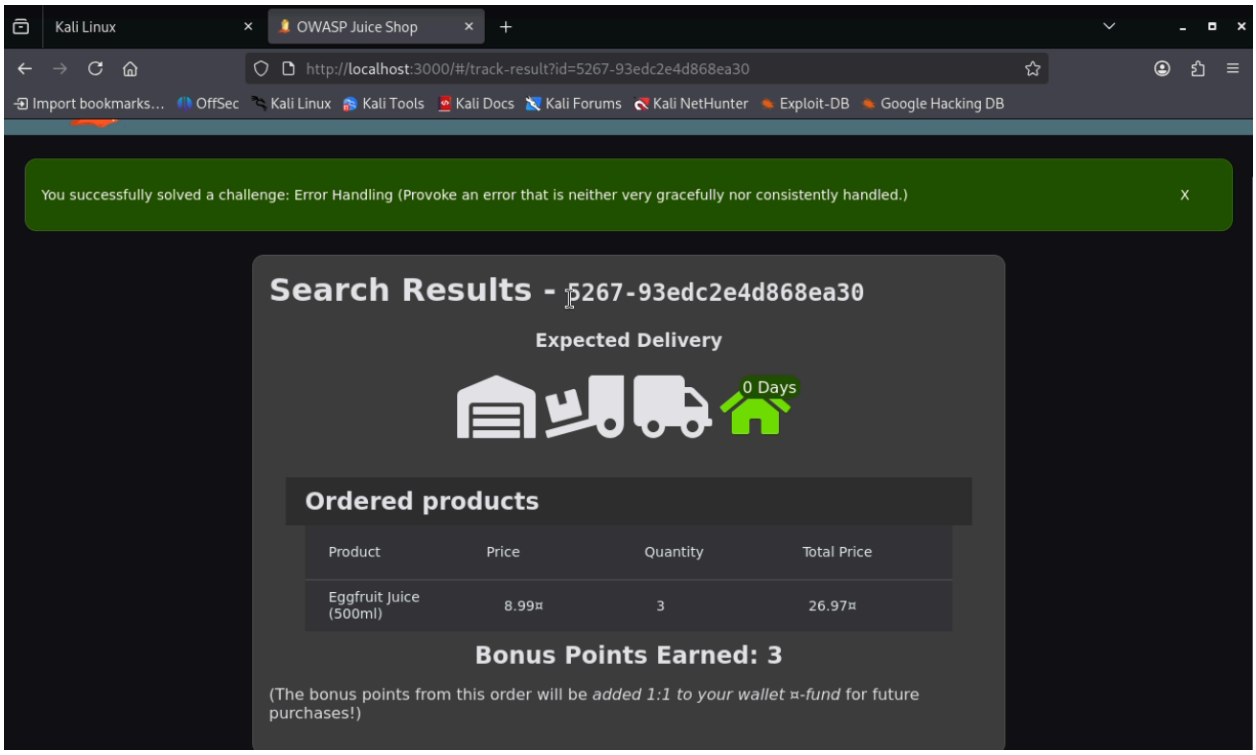



Kali Linux
OWASP Juice Shop
http://localhost:3000/#/search
Import bookmarks...
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OWASP Juice Shop
Account
Your Basket
6
EN
You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)
Jump to related coding challenge
All Products
Click for more information
Apple Juice (1000ml)
Apple Pomace
Banana Juice (1000ml)
This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!
Me want it!

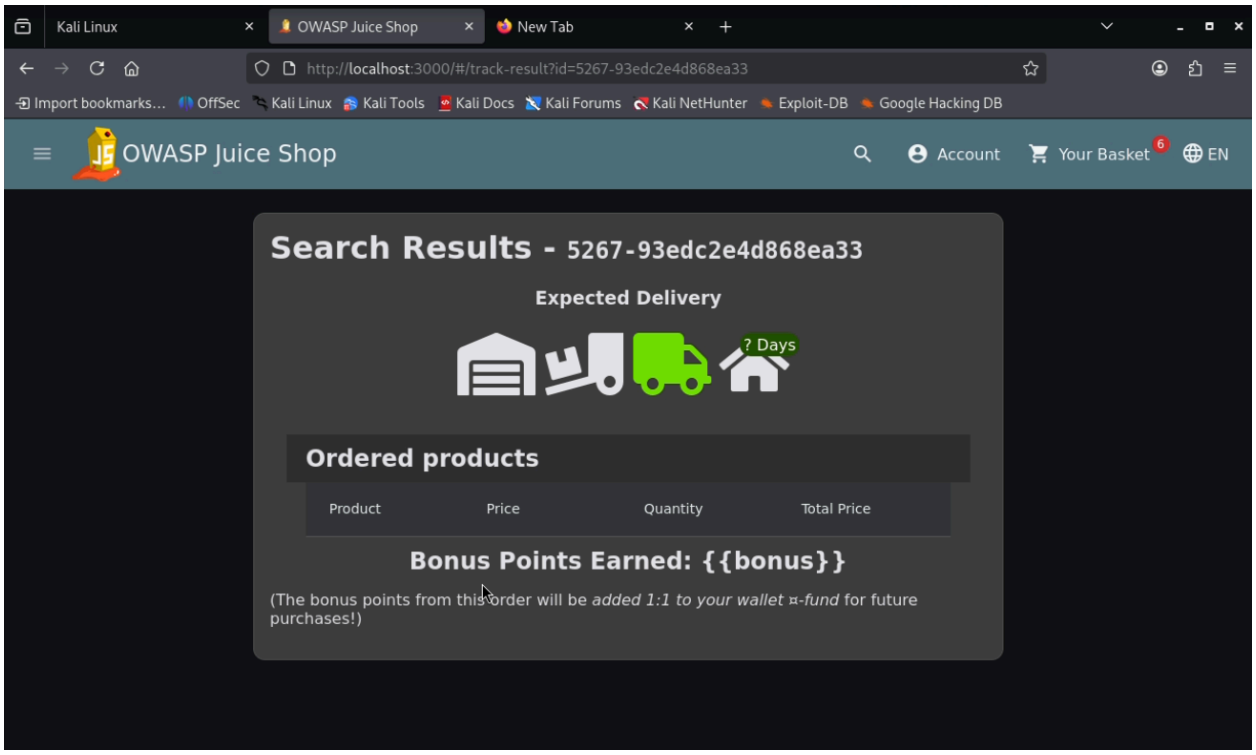
"Task Two: Cross-Site Scripting - XSS Payload Result"



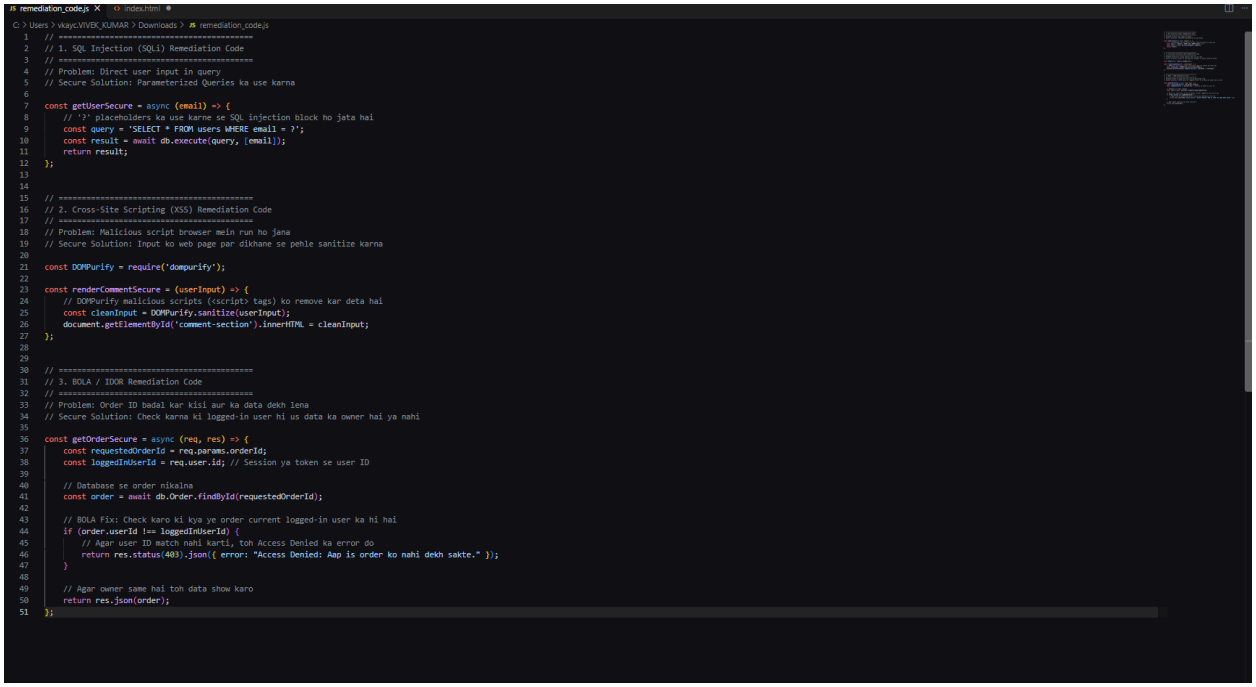
"Task Three Point One : Authorization Issues - Original Order Details"



"Task Three Point Two: Authorization Issues - Modified Order Details"



"Task Four: Remediation Code"



remediation_code.js index.html

C: > Users > vkayc.VIVEK_KUMAR > Downloads > remediation_code.js

```
// ==========================================
// 1. SQL Injection (SQLi) Remediation Code
// ==========================================
// Problem: Direct user input in query
// Secure Solution: Parameterized Queries ka use karna

const getUserSecure = async (email) => {
    // '?' placeholders ka use karne se SQL injection block ho jata hai
    const query = 'SELECT * FROM users WHERE email = ?';
    const result = await db.execute(query, [email]);
    return result;
};


// ==========================================
// 2. Cross-Site Scripting (XSS) Remediation Code
// ==========================================
// Problem: Malicious script browser mein run ho jana
// Secure Solution: Input ko web page par dikhane se pehle sanitize karna

const DOMPurify = require('dompurify');

const renderCommentSecure = (userInput) => {
    // DOMPurify malicious scripts (<script> tags) ko remove kar deta hai
    const cleanInput = DOMPurify.sanitize(userInput);
    document.getElementById('comment-section').innerHTML = cleanInput;
};


// ==========================================
// 3. BOLA / IDOR Remediation Code
// ==========================================
// Problem: Order ID badal kar kisi aur ka data dekh lena
// Secure Solution: Check karna ki logged-in user hi us data ka owner hai ya nahi

const getOrderSecure = async (req, res) => {
    const requestedOrderId = req.params.orderId;
    const loggedInUserId = req.user.id; // Session ya token se user ID

    // Database se order nikalna
    const order = await db.Order.findById(requestedOrderId);

    // BOLA Fix: Check karo ki kya ye order current logged-in user ka hi hai
    if (order.userId !== loggedInUserId) {
        // Agar user ID match nahi karti, toh Access Denied ka error do
        return res.status(403).json({ error: "Access Denied: Aap is order ko nahi dekh sakte." });
    }

    // Agar owner same hai toh data show karo
    return res.json(order);
};
```